

Decision Rationale

Why the Harborline Cyber Protection Policy is built the way it is

COMPANION DOCUMENTS

Specimen policy HIC-CY-100 with Declarations · Sample application
HIC-CY-APP

SAMPLE INSURED

Cedar Ridge Accounting Group, LLC
(fictional)

DATE

September
2026

The short version

I designed a single cyber policy for businesses with roughly \$1M–\$50M in revenue. The goal was that an owner could read it, a broker could sell it, and a claims team could pay it without argument. Five principles drove every decision:

1. **Cover what actually hurts small businesses, at full limits.** Ransomware, business interruption and breach response carry the full \$1M limit. Funds transfer fraud, the most frequent loss, gets a meaningful \$250K.
2. **Make the first 72 hours easy.** One hotline, free incident response that does not reduce the limit, and a one-page “what to do” guide in the Declarations.
3. **Reward security instead of voiding coverage over it.** Good controls earn visible credits. If a control lapses, the terms for that incident revert. The policy does not disappear.
4. **Draw bright lines around systemic risk.** War, infrastructure failure, non-malicious outages and website-tracking suits are excluded or sold as priced options, so the core price stays affordable.
5. **Write for the reader.** Plain English, consistent coverage letters, an “In short” note on every coverage, and definitions that each do one job.

1 How I approached it

Before drafting, I catalogued more than 400 publicly available cyber insurance documents (wordings, specimens, declarations and applications) to see how the market actually handles each design question. I then compared a shortlist of current small-business forms closely: At-Bay, Coalition, Vouch and Corgi's own cyber form, [1–4] backed by Beazley, Crum & Forster, HSB and Chubb forms. [6–9] For each decision I asked three questions:

- **What do the leading forms do, and where do they disagree?** Disagreement marks a real judgment call.
- **What does the loss data say?** I used At-Bay's 2026 InsurSec Report claims data to size limits and retentions. [5]
- **What does the law or regulator require?** Examples are sanctions rules on ransom payments, breach-notification deadlines, war-exclusion standards and the federal terrorism disclosure. [11–16]

I used the NIST Cybersecurity Framework 2.0 to organize the application's security questions, so every underwriting question ties to a recognized control category rather than an insurer's preference. [10]

2 Structure and format

DECISION	WHAT I CHOSE	WHY
One form, core plus options	12 core coverages (A–L) always included; 6 optional (M–R) switched on in the Declarations	At-Bay and Coalition bundle everything; Corgi and Vouch are more modular. [1–4] A hybrid keeps the biggest small-business risks covered by default, so nobody is underinsured by accident, while still letting buyers add niche cover. Everything lives in one form, rather than the 20+ endorsements At-Bay's issued policy carried. [1]
Two triggers	Liability (I–L, Q): claims-made and reported. First-party (A–H, M–P, R): discovered during the policy period.	Lawsuits can arrive years after a breach, so liability needs a claims-made trigger with a retroactive date to keep the insurer's exposure definite. First-party losses are known when discovered, so a discovery trigger is simpler and fairer. This matches the leading forms. [2, 6, 7]
Organized around the reader's questions	Section I What we cover · II Definitions · III What we don't · IV How much · V What to do · VI Other rules	An owner reading during an incident is asking “am I covered, what do I pay, what do I do now?” The contents page maps those questions to sections, and coverage letters are identical in the Declarations and the form.
Plain English with “In short” notes	Short sentences, “you/we”, a one-line summary above each coverage	Clarity is the first thing a small buyer notices. Coalition and At-Bay state the same warnings in all-caps legalese. I kept legal precision in the clauses and added summaries for navigation.
Admitted insurer	Filed, admitted form in Colorado	Coalition writes on admitted paper; At-Bay and Vouch mostly write surplus lines. [1–3] Admitted status gives a regulator-reviewed form and state guaranty fund protection, both of which matter to small businesses.

TRADE-OFF Plain-English summaries can be used against an insurer if a court finds the summary and the clause inconsistent. I kept the summaries short and descriptive, and Section VI.U says they are not contract terms. Admitted paper also means slower rate and form changes than surplus lines, which I accepted for the trust it creates.

3 How I structured the definitions

The definitions follow four rules: one concept per definition; alphabetical and numbered so cross-references are unambiguous; no chains of nested definitions where I could avoid them; and “including” always means a non-exhaustive list. The decisions that matter most:

DEFINITION	CHOICE	REASONING
“Incident” (Def. 28)	One umbrella term for every first-party event	One word lets a single trigger, a single retention rule (“one retention per incident”) and a single related-events rule work across all first-party coverages. Without it, each coverage needs its own mechanics and gaps appear between them.
“Discover” and “Executive” (Defs. 19, 20)	The clock starts when a partner, officer or IT lead knows	A junior employee's vague suspicion should not start the reporting clock or trigger the prior-knowledge exclusion. Small businesses outsource IT, so “Executive” includes an outsourced IT or security lead acting in that role.
“Security Failure” (Def. 59)	Expressly includes use of stolen or deceived credentials	Most small-business intrusions start with phished passwords. Saying so closes the argument that a login with valid credentials was “authorized.”

DEFINITION	CHOICE	REASONING
"Privacy Event" (Def. 47)	Any unauthorized disclosure, including paper records and employee mistakes	Many small-business breaches are not hacks: a lost laptop, a misdirected email of tax returns. Notification law applies either way, so coverage should too.
"Computer System" (Def. 9)	Includes employee devices used for work; includes vendor-hosted systems for breach and liability coverages only	Data in a cloud app is still your data for breach purposes. For business interruption, though, I kept your own systems (Coverage D) separate from a vendor's (Coverage E), so the correlated cloud-outage risk can carry its own sublimit.
"Deepfake" and "Social Engineering Fraud" (Defs. 16, 62)	AI-generated voice and video named explicitly	Impersonation by cloned voice or video is the fastest-growing fraud vector. Naming it removes doubt that it is covered.
"Callback Verification" (Def. 6)	Precise and auditable: a number on file or independently obtained, never one from the request, and recorded	The \$100K fraud cap turns on this definition, so it must be objective. Both sides can tell afterwards whether it was done.
"Period of Restoration" (Def. 44)	Until systems are restored and income recovers, capped at 180 days	Income does not recover the moment systems do; clients return gradually. The cap keeps the exposure finite.

4 Limits, retentions and sublimits

The numbers below are sized to At-Bay's 2026 small-business claims data [\[5\]](#) and set against what the benchmark forms offer. [\[1-4\]](#)

TERM	CHOICE	REASONING
Policy aggregate limit	\$1,000,000	At-Bay's and Coalition's small-business policies both used \$1M. The average claim for firms under \$25M revenue was about \$180K, and the average ransomware claim about \$508K. [5] \$1M covers a severe ransomware event with room for the liability claims that follow it (see Example 1).
Retention	Scaled by revenue: \$10,000 for \$5M–\$25M, cut to \$5,000 with security credits	At-Bay and Coalition use \$2,500, which fits micro-businesses. Vouch and Corgi use \$10,000, which fits mid-sized firms. Scaling by revenue covers the whole \$1M–\$50M market, and the credit rewards controls that reduce loss.
One retention per incident	Only the largest retention applies	A ransomware attack can trigger six coverages. Stating on the Declarations that the business pays once prevents the "three deductibles?" shock.
Incident response (A)	First 72 hours outside the limit, \$0 retention	Borrowed from Coalition. [2] Early expert help is the cheapest loss control there is. If calling costs nothing, owners call sooner. The 72-hour window and panel rates keep the insurer's cost bounded.
Ransomware, BI, restoration (C, D, F)	Full \$1M limit	These are the severe losses. Vouch's \$62,500 ransomware sublimit [3] sits far below the ~\$508K average ransomware claim. [5]

TERM	CHOICE	REASONING
Dependent BI (E)	\$500,000	Vendor-caused events were about 14% of At-Bay's claims. [5] One cloud outage can hit thousands of insureds at once, as the July 2024 CrowdStrike outage showed. Half the limit balances real protection against that accumulation risk; At-Bay offers \$1M, Vouch \$25K.
Fraud (H)	\$250,000; \$500,000 option (R)	Covers the ~\$208K average fraud loss for firms under \$25M; the option serves firms nearer the ~\$373K average in the \$25M–\$100M band. [5]
Fraud retention incentive	\$2,500 instead of \$5,000 if reported within 72 hours	Speed decides recovery: about 70% of fraud victims who reported within 3 days recovered some money, against 27% after 30 days. [5] A lower retention pays owners to report fast, which also reduces our loss.
BI waiting period and restoration period	8 hours; up to 180 days	8 hours is the market norm. [1–3] 180 days matches At-Bay and Coalition. Vouch's 90 days is too short when about 1 in 10 ransomware cases causes 30+ days of downtime and income takes longer still to recover. [5]
PCI (K), security improvements (G)	\$250,000; \$25,000	Most small businesses take cards through hosted pages, so PCI exposure is modest. Coverage G is small but closes the loop: the attack that happened once is the attack most likely to happen again.
Extended reporting	60 days automatic; 12 months at 75% or 24 months at 125%	Priced like At-Bay [1] and cheaper than Coalition's 100% / 150% / 200%, which is fairer for a small business closing or switching carriers.

5 What I included, made optional or left out

Core coverages (A–L)

Every core coverage answers a loss that small businesses report regularly: breach response and notification, extortion, downtime, data restoration, payment fraud, and the lawsuits and regulatory inquiries that follow a breach. Media liability is cheap to include and covers a real exposure, since every business now publishes content on its website and social media.

Optional coverages (M–R), and why each is optional

OPTION	WHY OPTIONAL RATHER THAN CORE
M · System failure BI	Non-malicious outages (a bad update, an IT error) are frequent and correlated: one vendor update can take down thousands of customers at once. Pricing it separately keeps the core affordable and lets firms that depend heavily on uptime buy it.
N · Bricking	Relevant mainly to firms with on-site hardware. Cedar Ridge bought it for its laptop fleet.
O · Reputational harm	Lost-profit-from-publicity is hard to measure for a small business and invites disputes about causation. It makes sense as an option for consumer-facing brands.
P · Cryptojacking and telecom fraud	Small, specific losses. Cheap to add for firms with cloud accounts or VoIP systems.
Q · Website tracking liability	Lawsuits over pixels and session replay under the California Invasion of Privacy Act and similar laws are concentrated in businesses that run advertising pixels. The application asks about tracking tools (Q. 4.5), so only the firms that need it pay for it.
R · Higher fraud limit	For firms with larger payment flows. It keeps the base price right for everyone else.

Left out entirely

- **Professional errors (E&O).** Exclusion III.A.11 keeps cyber and professional liability cleanly separate. A tax-preparation mistake belongs on an accountant's E&O policy, but a claim that a breach exposed a client's data stays covered here.

- **Biometric privacy suits.** Illinois's Biometric Information Privacy Act sets statutory damages of \$1,000 to \$5,000 per violation, [15] which creates liability out of proportion to a small-business premium. Theft of biometric data by a hacker is still covered.
- **Robocall and spam law (TCPA).** Marketing-practice risk rather than cyber risk.
- **Bodily injury, property damage and physical perils.** These belong to general liability and property policies. Coverage N is the one deliberate exception, for bricked hardware.

6 The exclusion decisions that took the most judgment

War and state-backed cyber operations (III.A.5)

Since March 2023 Lloyd's has required standalone cyber policies to exclude state-backed cyber attacks, and the Lloyd's Market Association published model clauses for doing so. [12] The NotPetya litigation, in which a court refused to apply a traditional war exclusion to a cyberattack, showed that vague wording helps no one. [17] I followed the model-clause structure but added three protections for the insured: the exclusion applies only to operations with a major impact on a state's essential services or security; systems outside the impacted state are carved back in; and the insurer carries the burden of proof, with a defined attribution process.

Infrastructure failure (III.A.6)

Widespread power or internet-backbone failures cannot be priced into a small-business premium. The exclusion states that a cloud or IT vendor is not “infrastructure,” so it cannot be used to deny a legitimate Coverage E claim.

Other lines I drew deliberately

- **Prior knowledge** turns on what an *Executive* knew before the continuity date, not on what anyone in the business might have known.
- **Intentional acts** apply only after a final ruling or admission. We defend until then, and a rogue employee's acts do not remove cover for the business.
- **Contractual liability** carves back confidentiality obligations and PCI terms. Small businesses routinely sign NDAs, business associate agreements and merchant agreements that promise data security.
- **Betterment** is excluded, except for the capped Coverage G upgrades and like-for-like hardware replacement under Coverage N.

7 Conditions: making it work in practice

CONDITION	CHOICE	REASONING
Security credit adjustment (IV.G)	If a credited control is missing when an incident starts, that incident reverts to un-credited terms	This is the most distinctive choice in the policy. Many forms exclude or void coverage for “failure to maintain” a represented control. That is harsh on small businesses whose controls lapse briefly, and it invites coverage fights. Reverting the specific credit (retention, ransomware coinsurance or fraud limit) keeps the incentive and keeps the business insured. Rescission is reserved for intent to deceive.
Legal notices never need consent (V.D)	Stated in the policy, the Declarations and the incident guide	Colorado requires notice to affected residents within 30 days, [14] and the FTC Safeguards Rule now requires tax preparers and similar firms to notify the FTC of breaches affecting 500 or more people. [13] An insured should never have to choose between the law and their coverage.

CONDITION	CHOICE	REASONING
Ransom payments (V.F)	Consent, sanctions screening, law-enforcement reporting where asked, and confirmation that restoring from backups is not a reasonable alternative	Tracks the Treasury (OFAC) advisory on ransomware payments. [11] Paying is always the insured's decision; we never require it.
Panel providers (V.C)	Panel use needs no consent; outside providers at panel rates; emergency costs covered if reported within 48 hours	Speed first, with cost control, and without trapping an insured who already has a trusted provider.
Settlement (V.H)	Duty to defend; soft "hammer" (70/30 split after a refused settlement)	Small businesses have no in-house counsel, so the insurer should defend. A soft hammer discourages unreasonable refusals without forcing a settlement on the insured.
Late notice (V.A)	Claims: firm 60-day post-period deadline. Incidents: late notice denied only if it caused real prejudice.	Claims-made coverage needs a firm reporting deadline to work. For first-party losses, a prejudice test is fairer and reflects how most courts approach late notice.
Small-business-friendly terms	Pro rata refunds on cancellation; automatic broadening (VI.R); optional risk services that never affect coverage	Each costs little and signals good faith, which matters when the buyer is not an insurance professional.

8 How it works in practice: three worked examples

All three use the sample insured, Cedar Ridge Accounting Group (Declarations: \$1M aggregate, \$5,000 retention, 8-hour waiting period, all three credited controls in place). Dollar figures are illustrative.

Example 1 · Ransomware in the middle of tax season

At 7:00 a.m. on a Monday in March, staff find files encrypted and a note demanding \$400,000 and threatening to publish stolen client data. Marcus Lee calls the hotline. The breach coach and forensic team are working remotely within the hour (Coverage A). Tested backups mean restoring is realistic, so, after negotiators assess the leak threat, Cedar Ridge decides not to pay. Systems are back by Friday. Forensics confirms that files covering 6,200 clients were copied. Colorado's attorney general opens an inquiry, and a class action follows five months later.

COVERAGE	WHAT IS PAID	AMOUNT
A · Incident response	Breach coach and forensic triage, first 72 hours (outside the limit, no retention)	\$38,000
B · Breach response	Further forensics and legal advice, notices and call center for 6,200 people, credit monitoring, PR	\$166,500
C · Extortion	Negotiator's threat assessment (no ransom paid)	\$9,500
D · Business interruption	Lost billings after the 8-hour waiting period (\$360,000), less work recovered in April (– \$180,000) and saved costs (–\$10,000); plus overtime and temporary staff (\$28,000) and a forensic accountant (\$6,000)	\$204,000
F · Restoration	Rebuilding systems and restoring data	\$46,000
G · Security improvements	24/7 MDR for a year and hardening the forensic team recommended (capped)	\$25,000
J · Regulatory	Defense of the attorney general inquiry (no penalty imposed)	\$28,000
I · Privacy liability	Class action defense (\$95,000) and settlement (\$150,000)	\$245,000
Loss within limits \$724,000 – one \$5,000 retention = Harborline pays \$719,000, plus \$38,000 of Coverage A outside the limit		\$719,000

Cedar Ridge pays \$5,000 and absorbs the first 8 hours of downtime; \$281,000 of the aggregate limit remains for the rest of the year. **Why the credits matter:** without the backup credit, 20% ransomware coinsurance would have cost Cedar Ridge about \$143,800 more. Without the MFA/EDR credit, the retention would have been \$10,000.

Example 2 · Two kinds of payment fraud

(a) Funds transfer fraud. Criminals steal online-banking access and wire \$148,000 out overnight. Cedar Ridge notices the next morning and calls its bank and the hotline within 6 hours. The bank recalls \$40,000. **Direct financial loss \$108,000, less the reduced \$2,500 retention (reported within 72 hours): Harborline pays \$105,500.** The callback rule does not apply, because nobody at Cedar Ridge was tricked into sending the money.

(b) Social engineering with a deepfake. An email and a follow-up call in a cloned voice of the landlord's property manager “update” the bank details for the \$62,400 rent payment. The clerk skips the callback, and Cedar Ridge reports the fraud the next day. Because the loss is under the \$100,000 cap, Harborline still pays \$59,900. Had the fraud diverted \$180,000, the missed callback would cap payment at \$100,000 instead of \$177,500. The cap costs nothing on everyday losses and bites only on large ones, which are exactly the losses a two-minute phone call prevents.

Example 3 · Where coverage deliberately stops

EVENT	RESULT	WHY
The cloud tax platform is hit by ransomware during filing week; Cedar Ridge loses \$150,000 of income over 3 days	Covered under E: \$150,000 (waiting period only, no dollar retention)	A security failure at a dependent business
A faulty security-software update crashes Cedar Ridge's own laptops for 2 days	Not covered	A non-malicious system failure needs optional Coverage M, which Cedar Ridge declined
The tax platform goes down because of its own coding error	Not covered	A non-malicious outage at a vendor is the most correlated cyber risk; no coverage in this form responds to it

Being explicit about these edges is intentional. A buyer should learn what is not covered from the policy and the application, not from a claim denial.

9 Trade-offs I weighed, and what I would do next

Alternatives I considered and rejected

- **Notification costs outside the limit** (Beazley's per-person approach [\[6\]](#)). This protects the limit in a large breach, but a small business struggles to understand it, and it adds pricing complexity. It is a candidate future option.
- **A flat ransomware sublimit or coinsurance for everyone.** I used coinsurance only where the backup control is missing, which targets the risk rather than penalizing good insureds.
- **A separate, higher fraud retention.** I chose the single retention plus the fast-reporting discount, which gives a better incentive and is simpler.
- **Reimbursement instead of a duty to defend.** This is cheaper for the insurer, but it leaves small businesses managing litigation they are not equipped for.

What a real launch would still need

- Actuarial pricing and rate filings, with state amendatory endorsements for each state (the Colorado endorsement is listed but not drafted here).
- Accumulation modelling and reinsurance for the correlated exposures: Coverages E and M, and the war-exclusion boundary.
- Panel provider contracts and rates, and claims-handling guidelines for the 72-hour service.
- Readability testing of the form and Declarations with real small-business owners, and review of the “In short” notes with regulators during filing.
- A decision on whether to add dependent-business system failure as a priced option, the gap shown in Example 3.

10 References

1. At-Bay. Issued cyber insurance policy (ASTRO America), 2025–26 policy term.
2. Coalition. Cyber Policy 3.0 (Active Cyber Policy), issued policy, 2025–26 policy term.
3. Vouch. Cyber insurance policy declarations, 2025–26 policy term.
4. Corgi. Cyber Liability policy form CORG-CY-0100.

5. At-Bay. *The 2026 InsurSec Report*. April 2026.

6. Beazley. Beazley Breach Response specimen policy form F00653 (02/2025). portal.bigimd.com/files/Membership%20Benefits/Cyber%20Liability%20Insurance/Beazley_SpecimenPolicyForm.pdf

7. Crum & Forster. Simple Cyber policy form, Version 6.0 (September 4, 2025). cfins.com/wp-content/uploads/2021/05/Simple-Cyber-General-v6-2025.09.04.pdf

8. HSB (Munich Re). Cyber Suite Coverage Form CSC (02-2025), as filed by Heartland Mutual Insurance. heartlandmutualinsurance.com/wp-content/uploads/2024/12/Cyber-Suite-Coverage-Form-CSC-02-2025.pdf

9. Chubb. Cyber Enterprise Risk Management small business specimen, PF-48169 (02/19). studio.chubb.com/connect/files/NA_CyberSmallBusiness_Sample.pdf

10. National Institute of Standards and Technology. *The NIST Cybersecurity Framework (CSF) 2.0*, NIST CSWP 29. February 2024. doi.org/10.6028/NIST.CSWP.29

11. U.S. Department of the Treasury, Office of Foreign Assets Control. *Updated Advisory on Potential Sanctions Risks for Facilitating Ransomware Payments*. September 21, 2021.

12. Lloyd's. Market Bulletin Y5381, "State backed cyber-attack exclusions," August 2022; Lloyd's Market Association model clauses LMA5564–LMA5567, November 2021.

13. Federal Trade Commission. Standards for Safeguarding Customer Information (Safeguards Rule), 16 C.F.R. Part 314, as amended; FTC breach-notification requirement effective May 13, 2024.

14. Colorado Revised Statutes §§ 6-1-713.5 (protection of personal identifying information) and 6-1-716 (notification of security breach).

15. Illinois Biometric Information Privacy Act, 740 ILCS 14/20 (statutory damages).

16. Terrorism Risk Insurance Act of 2002, as amended and extended by the Terrorism Risk Insurance Program Reauthorization Act of 2019.

17. *Merck & Co. v. ACE American Insurance Co.*, N.J. Super. Ct. App. Div. (2023) (war exclusion held inapplicable to the NotPetya cyberattack).

A Appendix: Declarations design log

My working notes from designing the Declarations page. Each element takes the strongest idea from a benchmark policy and adapts it for small businesses.

WHAT I CHOSE	BORROWED FROM	WHY IT IS BETTER
Numbered items (Item 1, 2, 3...)	Coalition	Cleanest structure of the pages reviewed; easy to reference ("see Item 7")
Plain-English notices at the top	Coalition's content, rewritten	The same warnings, without the all-caps legalese
"What it pays for" column	Corgi's plain-English style	An owner understands each coverage at a glance, on the Declarations itself
Security credits table	Coalition and At-Bay approaches	Shows exactly what was earned, and what is still available (MDR), on the page
Full prior acts plus continuity date	Coalition	Broad cover while still excluding problems already known
Three reporting channels plus legal-notice line	Coalition, plus regulatory research	Easy reporting; protects businesses facing 30-day state breach deadlines
Short forms list	Improvement on At-Bay	Optional coverages live in one form, not 20+ endorsements
Incident roadmap back page	At-Bay	Makes the Declarations useful in a crisis, not just paperwork